

基于生成论的网络安全分析能力调度系统

附录

李龙胜

2026 年 6 月 16 日

符号的锚点、公式的源头、常见问题的回答、许可证的全文。
这是整个理论体系的工具抽屉。

目录

1	附录 A：符号索引	1
1.1	告警分级与分析能力	1
1.2	柯克霍夫原则与安全定义	2
1.3	攻击方与博弈	2
1.4	生成步系统（数学基础）	2
2	附录 B：数学推导补遗	3
2.1	B.1 最优采样频率方程的推导（Math-51 核心公式）	3
2.2	B.2 贪心最优性定理的完整证明骨架	3
2.3	B.3 信息论下界的详细推导	4
3	附录 C：常见问题（FAQ）	4
4	附录 D：CC BY 4.0 许可证全文	5

1 附录 A：符号索引

本索引覆盖全四卷使用的关键符号。每个符号的正式锚点见维护工具包。

1.1 告警分级与分析能力

符号	含义
r_i	告警类别 i 的分析率（被分析的概率）， $r_i \in [0, 1]$
r^*	最优分析率，由贪心择优裁定

A_i	告警类别 i 攻击成功时的最大损失（货币化度量）
α_i	告警类别 i 对漏报的敏感度系数
β_i	告警类别 i 的结构特征常数, $\beta_i = \alpha_i A_i^2 / (2B_i)^2$
B_i	告警类别 i 的攻击手法变化率（带宽）
κ	单条告警的单位分析成本（时薪 $\times$ 耗时）
C	每日总分析能力预算（容量上限）
C_{consumed}	已消耗的分析能力（实部）
C_{reserve}	保留的分析能力（虚部）
$\mathcal{K}_{\text{covered}}$	当前分析能力有效覆盖的告警类型集合
V_{breadth}	虚部广度, $ \mathcal{K}_{\text{covered}} /K$
V_{risk}	虚部风险暴露, 未被覆盖类型的潜在损失之和
$q_{\min}$	同源关联优先策略的生效阈值

1.2 柯克霍夫原则与安全定义

符号	含义
θ	防御方的秘密参数集合 ($A_i^{\min}, \alpha_i$ 等)
ε	参数不可区分性的安全参数（越小越安全）
δ	参数周期性扰动的幅度
T_{rot}	参数扰动周期
q_{01}	蓝队伪造概率：将忽略伪装为分析
q_{10}	蓝队压制概率：将分析伪装为忽略
Δ	两个参数集合 θ_0 和 θ_1 对应的可观测差异
$M_{\max}$	攻击方对单个告警类型的探测预算上限
m^*	区分参数所需的最小探测次数（信息论下界）

1.3 攻击方与博弈

符号	含义
ℓ	攻击方的质量等级, $\ell \in [0, 1]$ （自动化程度与隐蔽性的权衡）
C_A	攻击方总资源预算（算力 + IP 池）
q_{hit}	单次攻击尝试命中防御方脆弱点的概率
ρ	攻击方对信息暴露的敏感度系数
$s(t)$	防御方分析能力饱和度, $s(t) = C_{\text{consumed}}(t)/C$
$\tau(t)$	防御方响应延迟（饱和指标之一）

θ_{mn}	攻击方 m 和 n 之间的协同参数, $\theta_{mn} \in [0, 1]$
---------------	---

1.4 生成步系统（数学基础）

符号	含义
$R_{\min}$	最小记录量（公设二的数学表达）
s_T	系统在逻辑时间 T 的状态
U	生成步（作用在状态上的操作）
$R(s, U)$	记录成本函数
$\mathcal{A}(s)$	状态 s 处允许的生成步集合
$J(\pi)$	路径 π 的累积记录成本
$f(s)$	单调进展函数（贪心最优性定理的条件）

2 附录 B：数学推导补遗

2.1 B.1 最优采样频率方程的推导（Math-51 核心公式）

设信号 $x(t)$ 有效带宽为 B ，动态范围为 A ，采样频率为 f_s ，奈奎斯特频率为 $2B$ 。定义无量纲分析率 $r \equiv f_s/(2B)$ 。

当 $r < 1$ 时，混叠误差导致的状态偏差成本为：

$$V(r) = \alpha A^2 \left(\frac{1}{r} - 1 \right)^2, \quad (r < 1).$$

评估成本为 $K(r) = \kappa f_s = 2B\kappa r$ 。

总成本 $J(r) = V(r) + K(r)$ 。对 r 求导并令其为零：

$$\frac{dJ}{dr} = -2\alpha A^2 \left(\frac{1}{r} - 1 \right) \frac{1}{r^2} + 2B\kappa = 0.$$

整理得：

$$\frac{\alpha A^2}{r^3} \left(\frac{1}{r} - 1 \right) = B\kappa.$$

引入信号特征常数 $\beta \equiv \frac{\alpha A^2}{(2B)^2}$ ，替换后得到无量纲方程：

$$\frac{1-r}{r^4} = \frac{\kappa}{2\beta}.$$

该方程在 $(0, 1]$ 内有唯一解 r^* 。最优采样频率为 $f_s^* = 2B \cdot r^*$ 。

2.2 B.2 贪心最优性定理的完整证明骨架

定理（贪心最优性定理）：设生成步系统 $\mathcal{G}$ 满足：

- (C1) 存在严格单调进展函数 $f: \mathcal{S} \rightarrow \mathbb{R}$ ，每步进展至少为 $\delta > 0$ 。
- (C2) 成本函数可分解为 $R(s, U) = R_{\text{base}}(f(s)) + R_{\text{trans}}(\Delta f)$ ，其中 R_{base} 单调不减， R_{trans} 严格凸且 $R_{\text{trans}}(0) = 0$ 。
- (C3) 累积记录成本不触及容量上限 C 。

则对任何初始状态 s_0 ，局部贪心路径也是全局累积成本最小的路径。

证明（交换论证骨架）：

设贪心路径为 $\pi^* = (U_0^*, U_1^*, \dots)$ ，假设存在另一条路径 π 使 $J(\pi) < J(\pi^*)$ 。令 T 为两条路径首次分歧的时刻。在时刻 T ，贪心选择的进展量为 Δ_T^* ， π 选择的进展量为 Δ_T ，由贪心定义有 $R(s_T, U_T^*) \leq R(s_T, U_T)$ 。

构造新路径 $\tilde{\pi}$ ：在第 T 步取 U_T^* ，从 $T+1$ 步开始，模仿 π 的后续步，但将每步的进展量按比例调整以保持总进展量一致。由 R_{trans} 的严格凸性， $\tilde{\pi}$ 的总成本严格小于 π 的总成本。重复此交换直至消除所有分歧，可得 $J(\pi^*) \leq J(\pi)$ ，矛盾。故贪心路径最优。

2.3 B.3 信息论下界的详细推导

设攻击方对告警类型 i 进行 m 次独立探测，每次探测伯努利试验，真实分析概率为 P_{obs} 。攻击方用频率 $\hat{P} = X/m$ 估计 P_{obs} 。

由 Chernoff-Hoeffding 不等式，对任意 $\varepsilon > 0$ ：

$$\Pr(|\hat{P} - P_{\text{obs}}| \geq \varepsilon) \leq 2e^{-2m\varepsilon^2}.$$

要使得估计误差超过 ε 的概率不超过 δ ，即 $2e^{-2m\varepsilon^2} \leq \delta$ ，解得：

$$m \geq \frac{1}{2\varepsilon^2} \ln \frac{2}{\delta}.$$

代入 $\varepsilon = 0.01, \delta = 0.001$ ，得 $m \geq 38000$ 。

攻击方要区分 θ_0 和 θ_1 ，需满足 $\Delta = |P_{\text{obs}}(\theta_0) - P_{\text{obs}}(\theta_1)|$ 。区分优势满足 $\Pr[\text{猜对}] \approx \Phi(\Delta\sqrt{m})$ ，其中 Φ 是标准正态累积分布。要达 90% 成功率需 $\Delta\sqrt{m} \geq 1.28$ ，即 $m \geq (1.28/\Delta)^2$ 。当 $\Delta = 0.01$ 时 $m \geq 16384$ ，与 Chernoff 下界一致。

3 附录 C：常见问题（FAQ）

C.1 这和设备的威胁评级有什么区别？

设备评的是“这个攻击有多危险”，我们算的是“这个告警值不值得花时间去查”。一个高危告警如果每次都自动被阻断，查它就是浪费人力。

C.2 如果我漏掉了一条告警导致出事，谁负责？

这套算法的逻辑是帮您把时间花在最可能出事的地方。如果出事，出事的告警一定是被算法标注为“低分析率”的——那您需要反思的是：为什么这个本该是高分分析率的告警，您当初给它标了低损失值？

C.3 需要什么样的技术栈？

只需要三种东西：一张台账表（Excel 或 MySQL）、一个可以运行 Python 脚本的服务器、以及安全设备的数据接口。不需要机器学习，不需要大数据平台。

C.4 我的团队很小，这样做有意义吗？

团队越小，越需要把力气用在刀刃上。小团队根本不可能处理所有告警。

C.5 初始参数怎么填？

初期手工分档：核心服务器告警 $A = 10^6$ 元，普通终端 $A = 10^4$ 元，自动阻断告警 $A = 10^2$ 元。 α 统一设为 1.0。后续依靠自适应反馈机制自动校准。

C.6 柯克霍夫原则要求参数保密，但合规审计怎么办？

参数本身加密存储，审计时可以证明确实存在参数管理和扰动机制，但不需要公开参数的精确值。与密码学中密钥管理类似：可以证明密钥存在且被妥善管理，而不需要公开密钥本身。

4 附录 D：CC BY 4.0 许可证全文

本项目全部文档（包括全四卷及本附录）采用知识共享署名 4.0 国际公共许可证（CC BY 4.0）。

您可以自由地：

- 共享—在任何媒介以任何形式复制、发行本作品。
- 改编—修改、转换或以本作品为基础进行创作。
- 用于任何目的，包括商业目的。

惟须遵守下列条件：

- 署名—您必须给出适当的署名，提供指向本许可协议的链接，同时标明是否对原始作品作了修改。您可以用任何合理的方式来署名，但不得以任何方式暗示许可人为您或您的使用背书。

CC BY 4.0 完整法律文本参见：

<https://creativecommons.org/licenses/by/4.0/legalcode>

文档信息：

- 作者：李龙胜
- 版本：v1.0（与四卷体系同步发布）
- 许可：CC BY 4.0